

IDENTITY LIFECYCLE (JML) AUDIT

Access Risk Assessment — Link3IT Hybrid Identity Environment

Prepared by Andrew Symister · Framework: NIST SP 800-53 Rev. 5 (Access Control family)

1. Executive Summary

This audit assessed identity lifecycle controls across a hybrid identity environment consisting of an on-premises Active Directory domain (Link3IT.com) synchronized to Microsoft Entra ID, with privileged accounts governed by CyberArk and identity events forwarded to Splunk. The assessment evaluated whether accounts in the directory are traceable to an authoritative personnel source, whether inactive accounts are disabled, and whether lifecycle events (joiner, mover, leaver) are governed consistently.

The environment demonstrates strong control design — an authoritative HR feed drives provisioning, access certification campaigns run with automated remediation, and Conditional Access enforces MFA with documented break-glass exclusions. However, the audit identified a significant reconciliation gap between the authoritative source and the directory, along with a population of stale, shared, and test accounts that remain enabled.

Key findings at a glance

ID	Finding	Control	Risk
F-01	34+ enabled accounts have no corresponding record in the authoritative HR source	AC-2	HIGH
F-02	39 enabled accounts show no logon activity in 90+ days	AC-2(3)	HIGH
F-03	Shared/functional accounts in use without individual accountability	AC-2, IA-2	MEDIUM
F-04	Test and placeholder accounts remain enabled in the directory	AC-2	MEDIUM
F-05	Service accounts lack documented ownership and review cadence	AC-2, AC-6	MEDIUM
F-06	Account created outside the governed provisioning process (splunktest)	AC-2	MEDIUM

2. Scope & Methodology

Environment: On-premises Active Directory (Windows Server 2022, LDAPS via AD CS) synchronized to Microsoft Entra ID via Entra Cloud Sync; CyberArk for privileged access; Splunk for identity event collection.

Authoritative source: HR feed containing 5 personnel records (3 human workers, 2 non-human/service identities).

Framework: NIST SP 800-53 Rev. 5 — Access Control (AC) and Identification & Authentication (IA) families.

Period reviewed: Account inventory as of audit date; account-creation events reviewed over a 30-day window.

Evidence was gathered by querying Active Directory for enabled accounts and last-logon timestamps, comparing the directory population against the authoritative HR source, and reviewing Windows Security event 4720 (user account created) in Splunk.

3. Detailed Findings

F-01 — Accounts not traceable to an authoritative source

Control: AC-2 Account Management

Risk: HIGH

The authoritative HR source contains 5 personnel records. The directory contains approximately 39 enabled accounts reviewed in this sample. This leaves at least 34 enabled accounts with no corresponding record in the system of record, meaning they cannot be attributed to a current worker, contractor, or approved service.

Accounts that cannot be traced to an authoritative source are, by definition, unmanaged: no one owns them, no lifecycle event will disable them, and they will not appear in a personnel-driven offboarding process. This is the primary mechanism by which orphaned access persists after a worker departs.

- Recommendation: Reconcile the full directory population against the authoritative source. For each unmatched account, assign an owner, classify it (human, service, shared, test), and either bring it under governance or disable and remove it.
- Recommendation: Implement recurring automated reconciliation so the gap is detected continuously rather than at audit time.

F-02 — Inactive accounts remain enabled

Control: AC-2(3) Disable Accounts / AC-2(4) Automated Audit Actions

Risk: HIGH

39 enabled accounts show no interactive logon activity within the preceding 90 days. The majority have never recorded a logon. Enabled accounts with no usage represent unmonitored attack surface: credentials may be weak or unrotated, and compromise is unlikely to be noticed because there is no baseline of legitimate activity to deviate from.

Note: a subset of these are service accounts that do not authenticate interactively and therefore will not populate a last-logon timestamp. These require a different validation method (see F-05) and should not be treated identically to dormant human accounts.

- Recommendation: Define an inactivity threshold (commonly 90 days for human accounts), and automatically disable accounts exceeding it after owner notification.
- Recommendation: Separate human and non-human accounts before applying inactivity logic, to avoid disabling functioning service identities.

F-03 — Shared and functional accounts without individual accountability

Control: AC-2 Account Management, IA-2 Identification and Authentication

Risk: MEDIUM

The directory contains accounts representing teams or job functions rather than individuals, including accounts for a security operations team, audit function, IAM operations, help desk, and several manager roles. Shared credentials break attribution: audit logs record the account, not the person, so actions cannot be traced to an individual.

- Recommendation: Replace shared accounts with individual accounts plus role-based group membership wherever technically possible.
- Recommendation: Where a shared account is genuinely required, vault the credential in a privileged access solution so check-out is attributed to a named individual and sessions are recorded.

F-04 — Test and placeholder accounts remain enabled

Control: AC-2 Account Management

Risk: MEDIUM

Accounts created for testing or as placeholders remain enabled in the directory, including a CPM test account, a Splunk test account, and accounts with placeholder surnames. Test accounts are frequently created with weak or shared passwords and are rarely included in review cycles, making them attractive persistence targets.

- Recommendation: Establish a naming convention and expiration requirement for test accounts, and disable them automatically at a defined interval.

F-05 — Service accounts lack documented ownership and review

Control: AC-2 Account Management, AC-6 Least Privilege

Risk: MEDIUM

The environment contains multiple service accounts supporting privileged access infrastructure, ITSM integration, HR integration, and monitoring. Service accounts commonly hold elevated permissions, have non-expiring passwords, and outlive the projects that created them. Without a documented owner, a business justification, and a review cadence, they accumulate privilege and persist indefinitely.

- Recommendation: Maintain a service-account inventory recording owner, purpose, permissions, and rotation method.
- Recommendation: Vault and rotate service-account credentials through the privileged access platform, and include them in a recurring review separate from human access certification.

F-06 — Account created outside the governed provisioning process

Control: AC-2 Account Management

Risk: MEDIUM

Review of account-creation events (Windows Security event 4720) over a 30-day window identified an account created that does not correspond to any record in the authoritative source. Directory-level creation events also show accounts created directly by an administrator rather than through the automated provisioning engine.

Provisioning that bypasses the governed process produces access that no downstream control is aware of. It will not be certified, will not be offboarded by a personnel event, and will not appear in access reports built from the authoritative source.

- Recommendation: Alert on account-creation events where the created account has no matching authoritative record.
- Recommendation: Restrict direct account creation to break-glass scenarios and require documented justification.

4. Controls Operating Effectively

The following controls were observed to be designed and functioning, and are noted as environment strengths:

- AC-2 — An authoritative HR source drives automated provisioning, with correlation on a unique employee identifier to prevent duplicate identities.
- AC-2(j) — Access certification campaigns were executed with automatic remediation enabled; denied access was revoked on completion, producing audit evidence.
- IA-2(1) — Multifactor authentication is enforced through Conditional Access policy for interactive users.
- AC-2 / CP-2 — A break-glass emergency account exists and is excluded from access policy, with the exclusion validated in report-only mode prior to enforcement.
- AU-6 — Identity events are forwarded to a SIEM, enabling correlation of directory activity against the authoritative source.

5. Remediation Plan

Priority	Action	Finding	Target
1	Reconcile directory against authoritative source; assign owner or disable each unmatched account	F-01, F-06	30 days
2	Classify accounts as human / service / shared / test; apply inactivity disable policy to human accounts	F-02, F-04	30 days
3	Build and populate service-account inventory with owner, purpose, and rotation method	F-05	60 days
4	Replace shared accounts with individual accounts plus role groups; vault any that must remain	F-03	90 days
5	Implement continuous reconciliation alerting on accounts created outside governance	F-01, F-06	90 days

6. Conclusion

The environment demonstrates mature control design: provisioning is driven by an authoritative source, access certification runs with enforced remediation, and multifactor authentication is applied through policy with a tested break-glass path. The weakness is not in design but in reconciliation — the directory population has drifted beyond what the authoritative source accounts for.

This is the most common and most consequential identity finding in practice. Access that no one owns is access that no process will remove. Closing the reconciliation gap, classifying the account population, and establishing continuous detection of ungoverned account creation would materially reduce access risk in this environment.

Environment note: this assessment was performed in a self-built laboratory environment constructed to practice identity governance operations. Findings, evidence, and remediation guidance reflect real queries against live systems.